
THROUGH THE LENS MEDIA

Information Security Policy

Lumière Ledger — Financial Management Platform

Document Version:	2.0
Effective Date:	May 18, 2026
Classification:	Confidential — Compliance Use
Owner:	Joshua Deuermeyer, Owner & Developer
Contact:	joshua.deuermeyer@gmail.com
Business:	Through The Lens Media, Las Vegas, NV
Platform:	Lumière Ledger (www.lumiereledger.com)

This document contains confidential security information. Distribution is restricted to authorized personnel and compliance reviewers only.

Table of Contents

1. Purpose and Scope
2. Organizational Security — Governance
3. Access Control and Identity Management
4. Data Classification and Handling
5. Encryption
6. Network and Application Security
7. Third-Party and Vendor Risk Management
8. Incident Response
9. Business Continuity and Availability
10. Physical and Environmental Security
11. Audit, Monitoring, and Logging
12. Policy Review and Enforcement

1. Purpose and Scope

This Information Security Policy (ISP) establishes the security framework, controls, and responsibilities for Through The Lens Media (TTLM) and its Lumière Ledger financial management platform. It governs the confidentiality, integrity, and availability of all data processed, stored, or transmitted by TTLM systems.

Lumière Ledger is a SaaS-based financial management application for freelance photographers and creative professionals. The platform processes financial transaction data and, via a pending Plaid integration, will facilitate secure bank account connectivity using OAuth-based token exchange. At no point does the platform store end-user banking credentials.

Scope covers:

- The Lumière Ledger web application hosted on Vercel (www.lumiereledger.com)
- The Express.js REST API backend serving the application
- The Supabase PostgreSQL database and file storage
- All Plaid API integrations and financial data handling
- Cloud service providers and third-party vendors
- All development, staging, and production environments
- The sole employee and owner: Joshua Deuermeyer

2. Organizational Security — Governance

Through The Lens Media is a sole-proprietor business. All information security responsibilities are owned and executed by Joshua Deuermeyer, Owner and Developer, who serves as the de facto Chief Security Officer, Data Protection Officer, and Incident Response Lead.

Security Responsibilities

Role	Responsibility	Individual
Security Owner	Policy governance, risk acceptance, compliance oversight	Joshua Deuermeyer
Developer	Secure code, dependency management, security testing	Joshua Deuermeyer
Incident Lead	Detection, containment, notification, remediation	Joshua Deuermeyer
Data Custodian	Data classification, retention, access controls	Joshua Deuermeyer

Security Policy Operationalization

Security policies are operationalized through automated controls embedded in the application architecture: Supabase Row-Level Security (RLS) policies, JWT-based API authentication, HTTPS-only transport, and Vercel's managed infrastructure security. Manual controls include regular dependency audits, access reviews, and periodic policy review.

3. Access Control and Identity Management

Authentication

All user authentication is managed by Supabase Auth, which implements industry-standard email/password authentication and Google OAuth 2.0 SSO. Passwords are never stored in plaintext — Supabase uses bcrypt hashing. Session tokens are JWT-based with configurable expiry and automatic refresh.

API Authorization

Every API endpoint requires a valid JWT issued by Supabase Auth. The Express.js middleware validates tokens via JWKS on every request. Role-based access control (RBAC) is enforced via a user_roles table; elevated operations require explicit role verification.

Database Access Controls

- Row-Level Security (RLS) is enabled on all Supabase tables — every row is filtered by user_id = auth.uid()
- The Supabase service role key (which bypasses RLS) is stored exclusively as a server-side environment variable and is never exposed to clients
- The anonymous key (client-safe) grants only the permissions defined by RLS policies
- Defense-in-depth: the API layer adds an additional .eq('user_id', req.user.id) filter on all destructive operations beyond RLS

Administrative Access

- Production environment variables (API keys, secrets) are stored in Vercel's encrypted environment variable store
- Supabase dashboard access is protected by MFA-enabled Google account
- Vercel dashboard access is protected by MFA-enabled account
- GitHub repository is private; access is restricted to the owner
- All secrets are rotated immediately upon any suspected compromise

4. Data Classification and Handling

Classification	Data Types	Controls
Restricted (Highest)	Plaid access tokens, encryption keys, API secrets	Encrypted at rest (libsodium), server-side only, never logged
Confidential	Financial transactions, receipts, user PII, bank account metadata	RLS-enforced DB access, Signed URLs for files, HTTPS only
Internal	Application logs, error messages, analysis outputs	Access-controlled, no PII in logs, retention limits
Public	Marketing content, product documentation	No special controls required

Plaid Data Handling

- Bank credentials (username/password) are never seen, stored, or transmitted by TTLM — Plaid handles credential collection via their hosted Link UI

- Plaid access tokens are stored encrypted using libsodium (ENCRYPTION_KEY environment variable) in the Supabase database
- Only the minimum required Plaid product scopes are requested (Transactions, Auth)
- Financial data retrieved from Plaid is stored in user-scoped tables with RLS enforced
- Users can revoke bank access at any time, which triggers immediate Plaid item deletion

5. Encryption

Encryption in Transit

- All client-server communication is enforced over TLS 1.2+ (HTTPS). HTTP requests are automatically redirected to HTTPS by Vercel
- Vercel and Supabase manage TLS certificates via Let's Encrypt with automatic renewal
- API endpoints reject non-HTTPS connections at the infrastructure level
- WebSocket connections (Supabase Realtime) are secured over WSS (TLS)

Encryption at Rest

- Supabase (PostgreSQL) encrypts all data at rest using AES-256 at the storage layer
- Supabase Storage (receipt files) is encrypted at rest by the underlying cloud provider
- Plaid access tokens are additionally encrypted at the application layer using libsodium (XSalsa20-Poly1305) before database storage
- Environment variables and secrets are encrypted at rest in Vercel's secret store

Key Management

- Encryption keys are stored as environment variables in Vercel's encrypted secret store
- Keys are never committed to source code, logged, or included in error messages
- Key rotation policy: immediate rotation upon any suspected compromise; annual scheduled rotation

6. Network and Application Security

Infrastructure Security

- Application is hosted on Vercel (SOC 2 Type II certified). No self-managed servers
- Database is hosted on Supabase (SOC 2 Type II certified). No self-managed database infrastructure
- Network-level DDoS protection provided by Vercel's edge network
- Vercel automatically applies OS and runtime security patches — no manual patching required

Application Security Controls

- Input validation enforced on all API endpoints using Zod schema validation
- SQL injection prevented by Supabase's parameterized query interface — no raw SQL string concatenation
- CORS policy restricts API access to authorized origins only
- Content Security Policy (CSP) headers enforced on the frontend
- Dependency vulnerability scanning via npm audit on every deployment

- Secrets scanning enabled on the GitHub repository to prevent accidental credential commits

Vulnerability Management

npm audit is run as part of the CI/CD pipeline on every push. Critical and high-severity vulnerabilities are remediated within 7 days of discovery. Medium vulnerabilities are tracked and resolved within 30 days. Dependency updates are reviewed and applied on a bi-weekly cadence.

7. Third-Party and Vendor Risk Management

Vendor	Purpose	Certifications	Data Shared
Vercel	Application hosting & CDN	SOC 2 Type II	Application code, env vars
Supabase	PostgreSQL DB, Auth, Storage	SOC 2 Type II	All user data
Plaid	Bank account connectivity	SOC 2 Type II, PCI DSS	Plaid access tokens
Resend	Transactional email	SOC 2 Type II	User email addresses
Google Cloud	OAuth, Maps API	ISO 27001, SOC 2	OAuth tokens
Google Gemini	AI financial assistant	Google Cloud compliance	User-submitted queries
GitHub	Source code management	SOC 2 Type II	Source code only
UptimeRobot	External health monitoring	N/A (pings only)	None (public endpoint)

All third-party vendors are evaluated for SOC 2 or equivalent compliance certifications prior to integration. Vendor security posture is reviewed annually. Data sharing with vendors is limited to the minimum necessary for service delivery.

8. Incident Response

Incident Classification

Severity	Definition	Response Time
Critical	Data breach, unauthorized access, Plaid token exposure	Immediate — within 1 hour
High	Service outage, authentication failure, injection attempt	Within 4 hours
Medium	Elevated error rates, suspicious activity patterns	Within 24 hours
Low	Policy violations, non-critical vulnerabilities	Within 7 days

Response Procedures

- 1. Detect:** Monitoring via UptimeRobot alerts, Vercel error notifications, Supabase dashboard anomaly detection, and user-reported issues
- 2. Contain:** Revoke compromised credentials, disable affected API routes, rotate secrets, block suspicious IPs at Vercel edge
- 3. Assess:** Determine scope, affected users, and data exposure. Preserve logs for forensic analysis
- 4. Notify:** Affected users notified within 72 hours of confirmed breach per applicable regulations. Plaid notified per integration agreement
- 5. Remediate:** Deploy fix, re-enable services, conduct root cause analysis
- 6. Document:** Post-incident report documenting timeline, impact, root cause, and corrective actions

9. Business Continuity and Availability

Recovery Objectives

Component	RTO	RPO	Mechanism
Web Application	< 15 min	N/A (stateless)	Vercel auto-redeploy from GitHub
API Layer	< 15 min	N/A (stateless)	Vercel serverless auto-recovery
Database	< 1 hour	< 24 hours	Supabase point-in-time recovery (PITR)
File Storage	< 1 hour	< 24 hours	Supabase Storage replication

Availability Controls

- External health monitoring via UptimeRobot — pings /api/health every 5 minutes with alerting
- Application deployed across Vercel's global edge network — no single point of failure
- Supabase project kept active via automated health-check ping to prevent free-tier suspension
- Full source code in GitHub — complete environment can be rebuilt from scratch within 2 hours
- Critical environment variables documented in a secure, offline password manager

10. Physical and Environmental Security

Through The Lens Media operates as a fully remote, cloud-native business. No on-premises servers, data centers, or network infrastructure are maintained. All computing infrastructure is hosted by SOC 2-certified cloud providers (Vercel, Supabase) who maintain physical security controls at their facilities.

Development Environment Controls

- Development is performed on a personal macOS workstation protected by FileVault full-disk encryption
- Screen lock activates after 5 minutes of inactivity
- Local development environment variables are stored in .env files excluded from version control via .gitignore
- Work is performed on a password-protected home network with WPA3 encryption
- No production data is stored locally — all data remains in cloud infrastructure
- Device is protected by macOS built-in security features including Gatekeeper and XProtect

11. Audit, Monitoring, and Logging

Logging

- All API requests are logged by Vercel's serverless infrastructure with request metadata (timestamp, path, status code, response time)
- Supabase Auth logs all authentication events (logins, failures, token refreshes)
- Application-level error logging captures exceptions without including PII or sensitive data
- Plaid API call logs are retained per Plaid's platform requirements
- Logs are retained for a minimum of 90 days

Monitoring and Alerting

- UptimeRobot: external availability monitoring every 5 minutes — alerts via email and SMS on downtime

- Vercel: real-time function error rate monitoring and alerting
- Supabase: database query performance monitoring and connection pool alerts
- Manual security review: quarterly review of authentication logs and API access patterns for anomalies

12. Policy Review and Enforcement

This Information Security Policy is reviewed and updated at minimum annually, or upon any of the following triggering events:

- A security incident or near-miss
- A material change in the application architecture or data processing practices
- A new regulatory or compliance requirement
- Integration of a new third-party vendor with access to sensitive data
- Plaid approval and activation of live bank connectivity

Policy Attestation

As the sole owner and operator of Through The Lens Media, I, Joshua Deuermeyer, attest that the security controls described in this policy are implemented, operational, and reviewed on the schedule described herein.

Joshua Deuermeyer

Owner & Developer, Through The Lens Media
joshua.deuermeyer@gmail.com

Date